AA2_EV01 · INFOGRAFÍA · CLASIFICAR Y EVALUAR AMENAZAS Y VULNERABILIDADES

¿Qué puede afectar los activos de una clínica veterinaria?

Aplicación de la metodología NIST SP 800-30 en la Clínica Veterinaria Huellitas S.A.S. (organización ficticia, Armenia, Quindío)

Erick Manuel Sang Cifuentes · Apropiación de los conceptos en ciberseguridad · Programa 23310008, ficha 3640188 · SENA, Centro de Comercio y Turismo, Regional Quindío · Instructora: Luz Dary Bautista Parra · Octubre de 2026

La situación. Huellitas atiende consultas, cirugías y vacunación. Sus activos más valiosos, valorados en la evidencia AA1, son el software de gestión veterinaria, las historias clínicas, la base de datos de propietarios, la facturación y el disco de copias de seguridad. Todos tienen nivel **crítico**.

La pregunta. ¿Qué amenazas pueden afectar esos activos, qué debilidades las dejan pasar y cuáles se atienden primero?

Conceptos clave

Amenaza: evento que puede dañar un activo (por ejemplo, un sismo o un correo de phishing).
Vulnerabilidad: debilidad que la amenaza aprovecha (por ejemplo, no tener copia fuera de la sede).
Riesgo = probabilidad × impacto sobre la confidencialidad, la integridad y la disponibilidad.

1 Los 9 pasos de NIST SP 800-30

1	2	3	4	5	6	7	8	9
Caracterizar el sistema	Identificar amenazas	Identificar vulnerabilidades	Analizar controles	Determinar probabilidad	Analizar impacto	Determinar el riesgo	Recomendar controles	Documentar resultados

El paso 1 se hizo en la AA1 con el inventario y la valuación de activos. Esta infografía desarrolla los pasos 2 a 8 (resaltados). El paso 9 es el informe y la matriz de riesgos de la AA3.

2 Amenazas y vulnerabilidades por categoría

Naturales
Fenómenos que no controla la organización

AMENAZAS

- **Sismo:** el Eje Cafetero es zona de amenaza sísmica alta (recuerdo de 1999)
- Tormentas eléctricas y descargas
- Vendavales y lluvias fuertes
- Inundación por aguacero o daño de tubería

VULNERABILIDADES

- Computador de recepción y disco de copias en la misma sede
- Equipos sin anclaje, en el piso o cerca de ventanas
- Sin plan de continuidad del negocio

Humanas
Acciones intencionales o errores de personas

AMENAZAS

- **Phishing** y ransomware por correo o WhatsApp
- Ingeniería social: falsos proveedores o clientes
- Acceso no autorizado a historias clínicas
- Errores de usuario: borrar o alterar registros
- Robo de equipos o de medicamentos de control
- Denegación de servicio contra la página de citas

VULNERABILIDADES

- Usuario y contraseña compartidos en el software
- Sin verificación en dos pasos ni capacitación
- Wifi de clientes en la misma red interna

Entorno
Condiciones físicas y servicios del lugar

AMENAZAS

- **Fallas eléctricas** y variaciones de voltaje
- Caída del proveedor de internet
- Temperatura y humedad en el rack del router
- Incendio (oxígeno y alcohol en el quirófano)
- Polvo y pelo de mascotas en los equipos

VULNERABILIDADES

- Sin UPS ni regulador de voltaje
- Un solo proveedor de internet, sin canal de respaldo
- Cableado expuesto, sin normas de cableado estructurado

3 Evaluación de amenazas por activo

Activo (valor AA1)	A. Naturales	A. Humanas	A. Entorno	Valor amenaza	Perfil
Software de gestión veterinaria (15)	2	5	4	**11**	
Historias clínicas (14)	2	5	3	**10**	
Disco de copias de seguridad (13)	4	3	3	**10**	
Base de datos de propietarios (13)	2	5	2	**9**	
Conexión a internet y router (12)	3	2	4	**9**	
Computadores de consultorio y recepción (12)	2	4	3	**9**	
Equipo de rayos X y analizador (12)	3	1	4	**8**	

Escala por categoría de 1 (muy baja) a 5 (muy alta); el valor de la amenaza es la suma (máximo 15), como en el ejemplo del componente formativo. ■ naturales ■ humanas ■ entorno. **Lectura:** las amenazas humanas pesan más sobre la información, y las naturales y del entorno sobre el hardware y las copias.

4 Probabilidad × impacto = riesgo

Amenaza → activo	Prob.	Impacto	Riesgo
Ransomware → software y copias	Alta	Alto	Alto
Acceso no autorizado → historias clínicas	Alta	Alto	Alto
Falla eléctrica → computadores y router	Alta	Medio	Alto
Sismo → disco de copias en sede	Media	Alto	Alto
Caída de internet → agenda y facturación	Media	Medio	Medio
Error de usuario → base de propietarios	Media	Medio	Medio
Polvo y humedad → rayos X	Baja	Medio	Bajo

	Impacto bajo	Impacto medio	Impacto alto
Prob. alta	Medio	Alto falla eléctrica	Alto ransomware · acceso no autorizado
Prob. media	Bajo	Medio internet · error de usuario	Alto sismo
Prob. baja	Bajo	Bajo polvo y humedad	Medio

Probabilidad: alta, si la amenaza es frecuente y no hay controles; media, si ocurre a veces o los controles son parciales; baja, si es rara o está controlada. **Impacto:** se mide sobre la confidencialidad, la integridad y la disponibilidad, y en las consecuencias económicas y legales (Ley 1581 de 2012).

5 Controles recomendados

Físicos
- UPS y regulador para el servidor, los PC y el router
- Equipos anclados, elevados del piso y lejos de ventanas
- Extintor y detector de humo junto al quirófano
- Gabinete cerrado para el router y control de acceso a la bodega de medicamentos

Técnicos
- Usuario individual con verificación en dos pasos
- Copias 3-2-1 cifradas, con una copia en la nube
- Antivirus y actualizaciones automáticas
- Wifi de invitados separada (VLAN) y un segundo canal de internet por datos móviles

Administrativos
- Capacitación trimestral sobre phishing e ingeniería social
- Perfiles por rol y revisión de accesos al retirarse alguien
- Plan de continuidad y prueba de restauración cada mes
- Política de tratamiento de datos (Ley 1581 de 2012)

Conclusión. En Huellitas, el mayor riesgo para la información no viene de la naturaleza sino de las personas: el phishing y los accesos con claves compartidas pueden afectar las historias clínicas y el software. Al mismo tiempo, un sismo o una falla eléctrica pueden dejar la clínica sin copias ni servicio. Por eso la prioridad es combinar **autenticación en dos pasos y capacitación** con **copias fuera de la sede y energía de respaldo**. Estos resultados alimentan la matriz de riesgos de la actividad 3.

Referencias

Ministerio de Hacienda y Administraciones Públicas. (2012). *MAGERIT v3: Metodología de análisis y gestión de riesgos de los sistemas de información. Libro I: Método*. Portal de Administración Electrónica.

Servicio Nacional de Aprendizaje [SENA]. (s.f.). *Metodologías de análisis y evaluación de riesgos* [Componente formativo 2]. Zajuna.

Stoneburner, G., Goguen, A. y Feringa, A. (2002). *Risk management guide for information technology systems* (NIST SP 800-30). National Institute of Standards and Technology.

Ley 1581 de 2012. Por la cual se dictan disposiciones generales para la protección de datos personales. 17 de octubre de 2012. Diario Oficial No. 48.587.

Nota. Organización y datos ficticios con fines académicos. Elaboración propia.